

UK Business AI Policy Template & Governance Pack

Practical AI Governance, GDPR Guidance and Staff Usage Policies for UK Organisations

Prepared by

[Your Company Name]

[Your Name / Job Title]

[Company Registration Number]

Document Details

Version: 1.0 (2026 Edition)

Review Date: [Insert Date]

Classification: Internal / Confidential

Produced in association with **Across AI** | www.acrossai.co.uk



⚠️ Disclaimer: This document is a governance template and practical guidance resource. It does not constitute legal advice. Businesses operating in regulated sectors should seek independent legal or compliance counsel tailored to their specific circumstances.

Table of Contents

01

Executive Summary

Why AI governance matters for UK businesses in 2026

02

What Is an AI Policy?

Scope, purpose and key governance components

03

AI Risks for UK Businesses

GDPR, shadow AI, hallucinations, cyber risks and more

04

Data Classification Framework

What data can and cannot be entered into AI systems

05

Acceptable AI Usage Policy Template

Fully editable policy for your organisation

06

Staff AI Training Checklist

Onboarding, awareness and manager review checklists

07

AI Governance Workflow

Visual approval and oversight process diagram

01

AI Incident Response Guidance

What to do when things go wrong — step-by-step

02

AI Disclosure Guidance

Customer transparency and ethical considerations

03

AI Compliance Checklist

GDPR, tools, training, monitoring and vendor checks

04

Future AI Governance Trends

UK regulation, client expectations and insurance

05

Editable Templates

Policy, staff agreement, approval and incident forms

06

Final Recommendations

Practical advice for UK SMEs adopting AI safely

How to Use This Document: Work through each section in order for initial implementation. Use the editable templates in Section 13 to create your organisation's bespoke documentation. Review this pack at least annually or when significant new AI tools are introduced.

Executive Summary

Artificial intelligence is no longer a future consideration for UK businesses — it is already present in your organisation, whether you are aware of it or not. From ChatGPT and Microsoft Copilot to AI-driven customer service tools and automated marketing platforms, AI is being used daily across UK workplaces. Without a formal governance framework, this usage creates significant legal, reputational, and operational exposure.

Why Businesses Now Need AI Policies

The UK's regulatory landscape has shifted significantly.

The Data (Use and Access) Act 2025 received Royal Assent on 19 June 2025, amending UK GDPR in important ways. Simultaneously, the Information Commissioner's Office (ICO) has intensified AI enforcement activity, publishing a new AI and Biometrics Strategy. UK businesses using AI now operate across multiple overlapping regulatory frameworks simultaneously — UK GDPR, the Data Protection Act 2018, the UK government's five AI principles, and (for those serving EU customers) the EU AI Act.

A formal AI policy protects your business, your staff, and your clients by establishing clear rules before problems arise.

The Rise of Shadow AI

Shadow AI refers to the use of AI tools by employees without the knowledge, approval, or oversight of their employer. Surveys consistently show that significant proportions of office workers use personal AI accounts on work devices or enter company data into public AI platforms. This is happening in your business right now, even if it has not been formally sanctioned.

Common shadow AI scenarios include staff pasting client emails into ChatGPT for summarisation, using free AI writing tools for proposals containing confidential pricing, or uploading internal documents to AI translation services. Each of these actions may constitute a data breach under UK GDPR.

GDPR Concerns

Personal data entered into third-party AI systems may be processed, stored, or used for training without adequate legal basis

Shadow AI Risk

Staff using unapproved AI tools with company data creates invisible data governance gaps

Reputational Risk

AI-generated misinformation or accidental disclosure can cause significant client and public trust damage

Governance Benefits

A clear AI policy builds staff confidence, reduces liability and demonstrates professionalism to clients

Key Regulatory Reference (2026): The Data Protection Act 2018 (Code of Practice on Artificial Intelligence and Automated Decision-Making) Regulations 2026 now require the Information Commissioner to prepare a formal code of practice on AI and automated decision-making. Organisations should monitor ICO guidance updates closely throughout 2026.

What Is an AI Policy?

An AI policy is a formal organisational document that establishes the rules, responsibilities, and boundaries governing how artificial intelligence tools and systems may be used within your business. It is not merely a technical document — it is a governance instrument that touches employment law, data protection, contract management, and professional standards.

Acceptable Usage

Defines which AI tools are approved for use, for which tasks, and under what conditions.
Prevents uncontrolled adoption of AI tools across the organisation.

AI Governance

Establishes ownership and accountability for AI decisions and outcomes.
Identifies who is responsible when AI produces incorrect or harmful outputs.

Staff Responsibilities

Sets out clear obligations for individual employees regarding AI use, including fact-checking requirements, prohibited activities, and reporting duties.

Customer Transparency

Defines when and how the organisation discloses AI involvement in communications, decisions, and deliverables to clients and customers.

Data Handling

Specifies which categories of data may or may not be entered into AI systems, aligned with UK GDPR obligations and confidentiality duties.

AI Oversight

Establishes human review requirements, ensuring that AI outputs are checked before being used in client-facing work, legal documents, or key business decisions.

What an AI Policy Is NOT

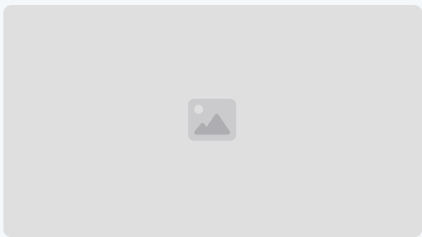
- It is **not** a ban on using AI tools — it is a framework for using them safely
- It is **not** a one-time document — it must be reviewed regularly as technology evolves
- It is **not** solely an IT document — it applies to every member of staff across every function
- It is **not** a substitute for GDPR compliance — it supports and reinforces it
- It is **not** just about ChatGPT — it covers all AI tools including Copilot, Grammarly AI, Canva AI, and more
- It is **not** optional if you process personal data using AI systems

AI Risks for UK Businesses

Understanding the risk landscape is the foundation of effective AI governance. The following table sets out the primary risk categories facing UK SMEs, with severity ratings and practical examples.

Risk Category	Severity	Description	UK Practical Example
GDPR Data Breach	● Critical	Personal data entered into public AI systems without a lawful basis or adequate data processing agreement	Staff pastes client contact list into ChatGPT to draft personalised emails — constitutes a likely GDPR breach reportable to the ICO
Confidential Data Exposure	● Critical	Commercially sensitive or legally privileged information entered into AI tools with no guarantee of confidentiality	Solicitor uses AI tool to summarise a client contract — confidential terms are sent to third-party servers
AI Hallucinations	● High	AI systems generating plausible but factually incorrect information, presented as accurate	AI cites a UK court case that does not exist; a proposal is sent to a client containing fabricated statistics
Misinformation Risk	● High	AI-generated content shared externally without adequate human review, spreading inaccurate claims	Marketing team publishes an AI-written blog containing incorrect regulatory figures — damages brand credibility
Legal / Compliance Liability	● High	AI-generated contracts, legal summaries, or compliance documents relied upon without professional review	Business uses AI to generate employment contracts without legal review — clauses are unenforceable under UK law
AI-Enabled Phishing	● High	Cyber criminals using AI to generate highly convincing, personalised phishing emails targeting your staff and clients	Finance director receives a near-perfect AI-generated impersonation email requesting urgent bank transfer
Shadow AI	● Medium	Employees using unapproved AI tools without management knowledge, outside governance controls	Account manager uses a free AI tool to draft a client report containing pricing and pipeline data
Intellectual Property Risk	● Medium	AI-generated content may reproduce copyrighted material or infringe third-party intellectual property rights	AI produces marketing copy that is substantially similar to a competitor's protected material
Discrimination / Bias	● Medium	AI tools producing biased outputs that could constitute unlawful discrimination under the Equality Act 2010	AI screening tool ranks CVs in a way that systematically disadvantages candidates from certain groups

Risk Severity Matrix



Use this matrix to prioritise which risks to address first when implementing your AI governance framework. Start with **Critical** risks — particularly GDPR and confidential data exposure — before addressing medium and low-severity concerns.

Data Classification Framework

Before any AI tool can be used in your organisation, staff must understand what category of data they are working with. This framework provides a practical classification system aligned with UK GDPR principles. Customise the examples column to reflect your own organisation's data types.

Classification	Definition	Examples	AI Usage Rules
 Public	Information that is already in the public domain and approved for external sharing	Published press releases, public website content, general industry statistics, published case studies	 May be used freely with standard AI tools. Always review AI outputs before publishing. Do not rely on AI-generated statistics without verification.
 Internal	Information for internal use only — not harmful if disclosed but not intended for public access	Internal meeting notes, general staff communications, internal project plans, internal training materials	 Use with caution. Only use with approved AI tools. Avoid tools that use inputs for model training. Confirm tool's data retention policy before use.
 Confidential	Sensitive business or client information — disclosure could cause significant harm	Client names and contact details, financial data, commercial proposals, contracts, pricing information, employee records, business strategies	 Do NOT enter into standard AI tools. Only permitted if: (a) tool has a signed DPA; (b) data is anonymised; (c) explicit management approval obtained. Document all uses.
 Restricted	Highly sensitive data — legal, regulatory, or contractual restrictions apply. Disclosure could cause serious harm	Special category personal data (health, ethnicity, religion), legally privileged documents, passwords and credentials, financial account details, data covered by NDAs	 Absolutely prohibited from AI tools in all circumstances. Breach may constitute a UK GDPR reportable incident. Escalate immediately if accidental entry occurs.

Practical Guidance: "Is it safe to use with AI?"



Step 1: Classify

Identify which data category applies to the information you are about to use



Step 2: Check the Tool

Confirm the AI tool is on your organisation's approved list and has a data processing agreement in place



Step 3: Anonymise

Where possible, remove or replace names, account numbers, and identifiable information before entering data into any AI system



Step 4: Review Output

All AI outputs must be reviewed by a human before being shared externally or used in decisions affecting individuals

 **Important — Anonymisation Note:** Simply removing a person's name does not always anonymise data under UK GDPR. If the remaining information could still identify an individual (e.g., their job title, location, and employer combined), it remains personal data and the same restrictions apply.

Acceptable AI Usage Policy Template

EDITABLE TEMPLATE — CUSTOMISE FOR YOUR ORGANISATION

 **Instructions:** Replace all text in [square brackets] with information specific to your organisation. This template is designed for UK SMEs. Legal review is recommended before final adoption, particularly for businesses in regulated sectors.

Policy Title: Artificial Intelligence Usage Policy
Organisation: [Organisation Name]
Version: [Version Number] | **Effective Date:** [Date] | **Review Date:** [Date]
Policy Owner: [Name / Role] | **Approved by:** [Director / Senior Manager Name]

1. Purpose and Scope

This policy sets out [Organisation Name]'s rules for the use of artificial intelligence (AI) tools and systems by all staff, contractors, and third parties acting on behalf of the organisation. It applies to all AI usage undertaken in connection with company activities, including usage on personal devices when handling company data.

2. Approved AI Tools

The following AI tools are approved for use within the organisation. Use of AI tools not on this list requires prior written approval from [Designated Approver]:

Tool Name	Permitted Use Cases	Data Restrictions	Approved By
[e.g. Microsoft Copilot]	[e.g. Drafting internal documents, summarising meetings]	[e.g. Internal data only — no client personal data]	[Name]
[e.g. ChatGPT Business]	[e.g. Research, content drafts, brainstorming]	[e.g. Public and anonymised internal data only]	[Name]
[Tool 3]	[Use cases]	[Data restrictions]	[Name]

3. Prohibited Activities

The following activities are **strictly prohibited** under this policy:

- Entering personal data of clients, employees, or third parties into any unapproved AI tool
- Using AI tools to generate legal documents, contracts, or compliance advice without qualified professional review
- Publishing or submitting AI-generated content without human review and verification of factual accuracy
- Using AI tools to make, or substantially influence, decisions about individual employees (recruitment, performance, dismissal) without human oversight
- Using personal AI accounts to process company data
- Attempting to "jailbreak" or circumvent the safety controls of any AI system
- Using AI-generated content in academic submissions or regulatory filings without permitted disclosure

4. Customer Data Restrictions

Customer and client personal data is classified as **Confidential** or **Restricted** under our Data Classification Framework. Staff must not enter customer personal data into AI tools unless: (a) the AI tool has a signed Data Processing Agreement (DPA) with [Organisation Name]; (b) the data has been appropriately anonymised; and (c) written approval has been obtained from [Designated Approver]. Any breach of this requirement must be reported immediately to [DPO / Privacy Lead] as it may constitute a notifiable incident under UK GDPR.

5. Human Review Requirements

All AI-generated outputs must undergo human review before being used for the following purposes:

- Client-facing communications, proposals, or reports
- Legal, contractual, or regulatory documents
- Marketing or public-facing content
- Decisions affecting employees or individual customers
- Financial analysis or advice

Standard of review: The reviewing individual must have sufficient knowledge and expertise to identify errors, hallucinations, or misleading content in the AI output. Rubber-stamp reviews without genuine assessment are not compliant with this policy.

6. Disclosure Requirements

Staff must disclose AI involvement in work products when: the AI tool substantially contributed to the output; a client or recipient has a reasonable expectation to know; professional standards or contractual obligations require it; or the business is asked directly. Disclosure wording should be agreed with [Designated Manager] and included in standard service agreements where relevant.

7. Disciplinary Considerations

Breach of this policy may result in disciplinary action in accordance with [Organisation Name]'s Disciplinary Procedure. Serious breaches — particularly those involving personal data, confidential information, or GDPR violations — may constitute gross misconduct.

8. Escalation Procedures

Staff should escalate to [Line Manager / DPO] in any of the following circumstances:

- Accidental entry of personal or confidential data into an unapproved AI tool
- Discovery of AI-generated content in circulation that contains factual errors or harmful information
- Uncertainty about whether a planned AI use is permitted under this policy
- Any request from a third party regarding AI-generated content produced by the organisation

Escalations should be reported within **[e.g. 4 hours]** of discovery. Do not attempt to resolve potential data breaches independently.

Staff AI Training Checklist

Effective AI governance depends on staff understanding. The following checklists should be used for onboarding new employees, conducting annual AI awareness reviews, and managerial oversight. Tick each item once completed and retain records for compliance purposes.

● **New Employee Onboarding Checklist**

Complete within first 5 working days

☐ AI Policy read and signed

☐ Approved AI tools list explained

☐ Data Classification Framework training completed

☐ Prohibited activities reviewed and understood

☐ Escalation and reporting procedures explained

☐ GDPR refresher completed (if handling personal data)

☐ Example scenarios walkthrough with line manager

☐ Access to AI tools provisioned (approved list only)

☐ Signed acknowledgement form filed in HR record

● **AI Awareness Checklist (All Staff – Annual)**

Complete annually and when policy is updated

☐ Annual AI policy review completed

☐ Shadow AI risks understood and discussed

☐ Phishing awareness: AI-generated phishing examples reviewed

☐ Fact-checking requirements understood — never trust AI output without verification

☐ GDPR reminder: personal data cannot be entered into unapproved tools

☐ Acceptable prompting guidance reviewed (see below)

☐ New approved tools (if any) added to knowledge

☐ Incident reporting procedure confirmed

☐ Any questions raised with line manager or DPO

● **Manager Review Checklist (Quarterly)**

Complete every quarter by line managers and department heads

☐ Confirm all direct reports have completed current AI training

☐ Check for any unapproved AI tools in use within the team

☐ Review any AI-related incidents or near-misses in the quarter

☐ Confirm all client-facing AI outputs are being reviewed before submission

☐ Review AI tool access and remove access for leavers

☐ Assess whether any new AI use cases require approval

☐ Confirm escalation procedures are understood and up to date

☐ Update AI usage log if new tools or use cases have been introduced

☐ Submit completed checklist to [DPO / Operations Manager]

Acceptable Prompting Guidance

Staff should follow these principles when constructing prompts for approved AI tools:

✔ Good Prompting Practice	✘ Poor / Risky Prompting Practice
Use general, anonymised descriptions: "a client in the manufacturing sector..."	Include real client names, account numbers or contact details in prompts
Ask AI to help structure your own ideas, then write the final content yourself	Copy-paste AI output directly into client documents without reading carefully
Treat all AI output as a first draft requiring human review and verification	Assume AI-generated statistics, legal citations or facts are accurate
Disclose AI assistance where professional or contractual obligations require it	Submit AI-generated work as entirely original without any review
Report any unexpected or concerning AI outputs to your line manager	Attempt to override AI safety controls or use "jailbreak" prompts

AI Governance Workflow

The following workflow sets out the standard process for requesting, approving, and implementing AI tools or AI use cases within your organisation. This process should be followed whenever a new AI tool is proposed or an existing tool is to be used for a new purpose.



This structured workflow ensures that no AI tool is adopted without appropriate oversight and that GDPR, confidentiality, and operational risks are assessed before any data is processed.

Governance Roles and Responsibilities

Role	Responsibilities	Escalation Point	Assigned To
AI Policy Owner	Owns and maintains the AI policy; ensures it is reviewed and updated at least annually	Board / Senior Management	[Name / Role]
Data Protection Officer (DPO)	Advises on GDPR compliance; reviews high-risk AI use cases; manages Data Processing Agreements	ICO (if required)	[Name / Role or External DPO]
Line Managers	First-line oversight of AI usage within their team; complete quarterly review checklist; escalate incidents	AI Policy Owner / DPO	All Department Managers
All Staff	Follow the AI policy at all times; complete training; report concerns and incidents promptly	Line Manager	All Employees
IT / Systems Admin	Provision approved tools only; manage access controls; monitor for shadow AI tool usage	AI Policy Owner	[Name / Role]

AI Incident Response Guidance

Despite the best governance measures, AI-related incidents can and do occur. This section provides clear guidance on how to respond to the most common AI-related incidents facing UK SMEs. Prompt, structured response is essential — both for limiting harm and for demonstrating compliance to the ICO.

Scenario A: Sensitive Data Entered into Unapproved AI Tool

A member of staff has entered client personal data, employee information, or commercially sensitive data into a non-approved AI system (e.g. a free consumer ChatGPT account).

Risk: Potential UK GDPR breach. Data may have been processed by a third party without a legal basis or Data Processing Agreement.

Scenario B: AI-Generated Misinformation Published

AI-generated content containing factual errors, false claims, or fabricated references has been shared with clients, published online, or submitted in a document without adequate review.

Risk: Reputational damage, potential professional liability, and client trust issues.

Scenario C: Accidental Disclosure via AI Output

An AI system has generated output containing information about another client, third party, or internal matter that was inadvertently disclosed — for example, within a shared AI session or prompt history.

Risk: Breach of confidentiality, potential GDPR violation, and contractual breach.

Universal AI Incident Response Checklist

Apply the following steps immediately upon becoming aware of any AI-related incident:

- ☐ 1. **Stop and contain** — cease use of the AI tool immediately; do not delete prompts or outputs (these are evidence)
- ☐ 2. **Report to line manager** — within 1 hour of discovery; provide a brief factual summary of what occurred
- ☐ 3. **Notify DPO / Privacy Lead** — within 4 hours if personal data is involved; they will assess whether ICO notification is required
- ☐ 4. **Document the incident** — record: what data was involved, which tool was used, what was entered, when it occurred, who was affected
- ☐ 5. **Assess ICO reporting obligation** — if a personal data breach is likely to result in risk to individuals' rights, the ICO must be notified within 72 hours under UK GDPR Article 33
- ☐ 6. **Notify affected individuals** — if the breach is likely to result in high risk to individuals, they must also be informed without undue delay (UK GDPR Article 34)
- ☐ 7. **Address published misinformation** — retract, correct, or clarify any AI-generated content that is factually incorrect; contact affected parties promptly
- ☐ 8. **Review AI tool access** — temporarily suspend access to the implicated AI tool pending investigation if appropriate
- ☐ 9. **Conduct root cause analysis** — identify how the incident occurred and what process failure allowed it
- ☐ 10. **Update controls and training** — implement changes to prevent recurrence; record lessons learned; update the AI policy if required

⊗ UK GDPR Reporting Deadline: If a personal data breach occurs, you have **72 hours** from becoming aware to report to the ICO — unless you can demonstrate the breach is unlikely to result in a risk to individuals. Do not delay. Failure to report within 72 hours can itself result in enforcement action.

AI Disclosure Guidance

Transparency about AI use is increasingly expected by clients, regulators, and the public. This section helps your organisation decide when and how to disclose AI involvement in your work — both as a matter of legal compliance and ethical business practice.

When Should You Disclose AI Usage?

Disclosure is required or strongly recommended in the following circumstances:

→ Legal or Regulatory Requirement

Where a professional code of conduct, contract, or regulatory obligation requires disclosure of AI involvement (e.g. legal sector, financial advice, healthcare communications)

→ Automated Decisions Affecting Individuals

Under UK GDPR Article 22, individuals have rights regarding solely automated decisions with significant effects — you must inform them and provide the right to contest

→ Client Contractual Expectations

Where a client has paid for bespoke human-created work and AI has substantially contributed — failure to disclose may constitute misrepresentation

→ AI-Generated Communications at Scale

Marketing emails, customer service responses, or proposals generated substantially by AI should be disclosed where the recipient would reasonably expect to know

Suggested Disclosure Language

Standard Disclosure (Light)

"This document was prepared with the assistance of AI tools and has been reviewed and approved by [Name / Role]."

Client Communications (Formal)

"Parts of this communication were drafted using AI writing assistance. All content has been reviewed by a qualified member of our team before sending."

Automated Decision Disclosure

"This [decision / assessment] was made using an automated process. You have the right to request human review of this decision by contacting [contact details]."

Ethical Considerations

Trust	Proactive disclosure of AI use builds long-term client trust. Businesses that are transparent about AI tend to be seen as more professional and credible, not less.
Accuracy	You are always responsible for the accuracy of AI-generated content you publish or share. AI hallucinations do not excuse factual errors in client-facing materials.
Fairness	Consider the impact of AI-generated decisions on different groups of people. AI systems can reproduce or amplify bias. Human oversight is both an ethical and legal safeguard.
Equity	Not all clients or customers are equally comfortable with AI. Consider whether AI usage is appropriate for particularly vulnerable individuals or sensitive circumstances.

AI Compliance Checklist

Use this checklist to assess your organisation's current AI governance position. Work through each item and record your status. Items marked **Not in Place** represent priority actions for your governance improvement plan.

Compliance Requirement	In Place 	Partial 	Not in Place 
GDPR & Data Protection			
GDPR-compliant Data Processing Agreement signed with each approved AI vendor	☐	☐	☐
Data Protection Impact Assessment (DPIA) completed for high-risk AI use cases	☐	☐	☐
Data Classification Framework in place and communicated to all staff	☐	☐	☐
Records of Processing Activities (ROPA) updated to include AI-related processing	☐	☐	☐
AI Tools & Approved Usage			
Approved AI tools register maintained and kept up to date	☐	☐	☐
Process in place to review and approve new AI tool requests	☐	☐	☐
Shadow AI monitoring approach in place (e.g. IT policy, user awareness)	☐	☐	☐
Staff Training & Awareness			
All staff have read and signed the AI Usage Policy	☐	☐	☐
AI training completed by all staff (including GDPR and phishing awareness)	☐	☐	☐
New employee AI onboarding checklist in use	☐	☐	☐
Monitoring & Review			
Quarterly manager AI review checklists completed and filed	☐	☐	☐
AI incident log maintained with documented incidents and actions taken	☐	☐	☐
AI policy reviewed and updated at least annually (or following significant changes)	☐	☐	☐
Supplier & Vendor Assessment			
AI vendor privacy policies reviewed for data retention and training data practices	☐	☐	☐
AI vendor security credentials reviewed (e.g. ISO 27001, SOC 2, Cyber Essentials)	☐	☐	☐
Contractual provisions in client agreements address AI usage and disclosure	☐	☐	☐
Governance Structure			
Named individual accountable for AI governance (AI Policy Owner) identified	☐	☐	☐
Incident response procedure documented and communicated to all staff	☐	☐	☐
Board or senior management have been briefed on AI governance obligations	☐	☐	☐

18

Total Checklist Items

Complete all 18 items to establish a baseline AI governance framework

72hrs

GDPR Reporting Window

Maximum time to report a personal data breach to the ICO from the point of discovery

£17.5M

Max GDPR Fine

Maximum UK GDPR fine (4% of global turnover or £17.5M, whichever is higher)

Future AI Governance Trends

UK businesses investing in AI governance today are positioning themselves for an increasingly regulated future. Understanding the direction of travel allows you to build frameworks that will remain compliant and commercially competitive as the landscape evolves.

UK Regulatory Direction

As of 2026, the UK does not have a single AI law. Instead, **the UK relies on existing legislation and a principles-based framework** from the 2023 AI White Paper, enforced through sector regulators. The five UK AI principles are:

01

Safety, Security & Robustness

AI systems should function reliably and securely

02

Transparency & Explainability

Users should understand how AI reaches decisions

03

Fairness

AI should not produce discriminatory outcomes under the Equality Act 2010

04

Accountability & Governance

Clear responsibility for AI system behaviour must exist within your organisation

05

Contestability & Redress

Individuals affected by AI decisions must be able to challenge them

EU AI Act – Implications for UK Businesses

UK businesses are not exempt from the EU AI Act. If your organisation deploys AI systems that affect individuals in EU member states, the Act likely applies. The key deadline is **2 August 2026**, when full compliance obligations for high-risk AI systems take effect. Fines can reach up to €35 million or 7% of worldwide annual turnover.

Rising Client and Procurement Expectations

Procurement Requirements

Larger clients and public sector buyers are increasingly requiring evidence of AI governance policies as part of supplier qualification. Expect this to become standard in tender processes by 2027.

Insurance Implications

Professional indemnity and cyber insurance providers are beginning to ask about AI usage policies during underwriting. Businesses without documented AI governance may face higher premiums or coverage exclusions.

Increasing Client Scrutiny

Enterprise clients are asking professional service providers to confirm AI governance policies. Having a documented, reviewed AI policy demonstrates the professionalism and due diligence that builds lasting commercial relationships.

Watch closely: The Data Protection Act 2018 (Code of Practice on AI and Automated Decision-Making) Regulations 2026 require the ICO to prepare a new statutory code of practice on AI. This will establish formal industry guidance later in 2026 — monitor ICO guidance at ico.org.uk for updates.

Editable Templates

Instructions: The following templates are designed to be copied, customised, and adopted as standalone documents within your organisation. Replace all [bracketed text] with your organisation's specific information. Seek legal review before finalising documents that will be used in regulated contexts.

Template A – One-Page AI Policy Summary (Staff Noticeboard / Intranet Version)

[Organisation Name] – AI Usage Policy Summary
Effective Date: [Date] | **Version:** [1.0] | **Policy Owner:** [Name]

We support the responsible use of AI tools. The following rules apply to everyone in our organisation:

☒ **You MAY use** the following approved AI tools for work purposes: [list approved tools]. Always review AI outputs before sharing or submitting them.

☒ **You must NEVER** enter personal data, client information, financially sensitive data, or legally privileged information into any AI tool that is not on the approved list.

☒ **You are always responsible** for anything you submit or publish. AI does not remove your professional accountability.

☒ **If something goes wrong**, report it to [Line Manager / DPO] immediately. Do not try to resolve data incidents yourself.

☒ **Full AI Policy** is available at [intranet link / file location]. Questions? Contact [Policy Owner].

Template B – Employee AI Agreement

Employee AI Policy Acknowledgement
I, **[Employee Full Name]**, of **[Job Title]**, confirm that I have read, understood, and agree to comply with [Organisation Name]'s Artificial Intelligence Usage Policy (Version [x], dated [date]).
I understand that:

- I must only use AI tools on the organisation's approved list for work purposes
- I must never enter personal data, client data, or confidential information into unapproved AI tools
- I am responsible for reviewing and verifying all AI outputs before submitting or sharing them
- I must report any AI-related incidents, errors, or data concerns to my line manager without delay
- Breach of this policy may result in disciplinary action, up to and including dismissal for serious breaches

Employee Signature: _____
Print Name: _____
Date: _____

Manager Signature: _____
Print Name: _____
Date: _____

Template C – AI Tool Approval Request Form

Requestor Name	[Full Name]
Department / Team	[Department]
Date of Request	[Date]
AI Tool Name	[Name of AI tool being requested]
Tool Provider / Vendor	[Company name and website]
Proposed Use Cases	[Describe exactly how the tool will be used and for which tasks]
Data Involved	[What types of data will be entered into this tool? Refer to the Data Classification Framework]
Data Processing Agreement	☐ DPA available from vendor ☐ DPA not available ☐ DPA review required
Estimated Number of Users	[Number of staff who will use this tool]
Estimated Monthly Cost	[£ amount or Free]
Line Manager Approval	Signature: _____ Date: _____
DPO / Compliance Review	☐ Approved ☐ Rejected ☐ Approved with conditions: [detail]
Final Decision	☐ Added to Approved Tools Register ☐ Rejected — reason: [detail]

Template D – AI Incident Reporting Form

Reporter Name	[Full Name]
Date / Time of Discovery	[Date and time]
AI Tool(s) Involved	[Name of AI tool(s)]
Nature of Incident	☐ Personal data entered into unapproved tool ☐ Confidential data exposure ☐ Misinformation published ☐ Accidental disclosure ☐ Other: [describe]
Description of Incident	[Provide a factual account of what occurred — what was entered, what happened, what was shared or published]
Data Categories Involved	☐ Personal data ☐ Special category personal data ☐ Confidential business data ☐ Client data ☐ No personal data involved
Number of Individuals Potentially Affected	[Estimated number]
Immediate Actions Taken	[Describe any steps already taken to contain or address the incident]
Line Manager Notified	Name: _____ Time: _____
DPO Notified	☐ Yes — Time: _____ ☐ No — Reason: _____
ICO Notification Required?	☐ Yes — Reported by: _____ ☐ No — Reason: _____ ☐ Under assessment
Form Completed By	Signature: _____ Date: _____

Final Recommendations

Implementing effective AI governance does not require a large budget or a dedicated compliance team. For UK SMEs, the key is to take a **practical, proportionate, and consistent** approach. The following recommendations are designed to help you get started and maintain momentum.

1 Start With What You Have

Before creating new processes, audit your current AI usage. Ask staff what tools they use and what data they enter. You may be surprised. Shadow AI is almost always more widespread than management expects. Understanding your actual starting position is essential before any governance programme can be effective.

2 Adopt This Policy Framework Today

Do not wait until UK AI legislation matures before acting. Your UK GDPR obligations are already in force and fully applicable to AI usage right now. Adopt and adapt the templates in this pack as your starting point. An imperfect policy that is in place is vastly more valuable than a perfect policy that never gets implemented.

3 Make Governance Proportionate to Your Size

A five-person agency does not need the same governance structure as a 500-person professional services firm. Apply the frameworks in this document at a scale appropriate to your organisation. What matters is that the key principles — approved tools, data classification, human review, and incident reporting — are embedded in your culture.

4 Treat AI Policy as a Living Document

The AI landscape changes rapidly. New tools emerge, new guidance is issued, and new risks are identified regularly. Schedule an annual policy review as a minimum. When significant new AI tools are adopted or major regulatory updates are published — such as the forthcoming ICO Code of Practice on AI — review and update your policy promptly.

5 Use Governance as a Commercial Asset

A documented, professionally presented AI governance policy is increasingly a commercial differentiator. Clients trust businesses that can demonstrate they handle AI responsibly. Procurement teams are beginning to ask for evidence of AI governance. By investing in this pack today, you are building both risk protection and competitive advantage simultaneously.

6 Seek Professional Support Where Needed

For businesses in regulated sectors — financial services, legal, healthcare, education — the intersection of AI governance with sector-specific regulation can be complex. Consider seeking advice from a qualified Data Protection Officer or legal adviser when implementing policies that affect high-risk or special category data. The cost of proper advice is always less than the cost of a regulatory investigation.

✔ **You Have Taken the First Step.** By working through this governance pack, your organisation is already ahead of the majority of UK SMEs in terms of AI readiness. Implement the templates, train your staff, and review regularly. If you need further support with AI strategy, governance, or staff training, visit www.acrossai.co.uk.

Document Produced By

[Your Company Name]
[Address Line 1]
[Address Line 2]
[Postcode]

Contact

[Email Address]
[Phone Number]
www.acrossai.co.uk

Document Version

Version 1.0 — 2026 Edition
Review Date: [Insert Date]
© [Organisation Name] [Year]